PERURI
SECURITY PAPER MILL

Dokumen internal · Versi 1.0
Oktober 2026

Dokumentasi teknis

Analisis Arsitektur Sistem E-Arsip PTKP

Sistem informasi manajemen persuratan dan pengarsipan elektronik berbasis web untuk mengotomatisasi siklus hidup dokumen internal dan eksternal.

Teknologi utama

CodeIgniter 3 (arsitektur MVC)
MySQL / MariaDB
AdminLTE 2
Ion Auth Engine
jQuery DataTables (Ignited DataTables)

Disusun oleh
Lead Software Architect & Systems Analyst

Target aplikasi
E-Arsip PTKP (PT Kertas Padalarang / Holding Peruri)

PT Kertas Padalarang · anak usaha Peruri
Pabrik kertas sekuriti sejak 1922

Daftar isi

1. Ringkasan Sistem (System Overview) . . . 3

1.1 Deskripsi singkat dan latar belakang . . . 3

1.2 Tujuan utama pengembangan . . . 3

1.3 Target pengguna dan batasan ruang lingkup . . . 4

2. Hak Akses dan Manajemen Peran (RBAC) . . . 5

2.1 Identifikasi peran (roles) . . . 5

2.2 Matriks hak akses (CRUD matrix) . . . 5

3. Alur Kerja dan Perilaku Sistem (System Workflow & Behavior) . . . 7

3.1 Analisis use case . . . 7

3.2 State flow: siklus registrasi dokumen dan korespondensi . . . 8

4. Arsitektur dan Struktur Database . . . 9

4.1 Diagram entitas relasi (ERD) . . . 9

4.2 Struktur tabel utama dan konstrain kunci . . . 10

5. Catatan Teknis dan Rekomendasi Arsitektural (Technical Audit) . . . 12

5.1 Redundansi data dan skema warisan (legacy schema debt) . . . 12

5.2 Pelanggaran normalisasi (1NF violation) . . . 13

5.3 Celah keamanan (security gaps) . . . 13

5.4 Race condition pada generator nomor surat . . . 14

6. Ringkasan Evaluasi Arsitektur (Executive Summary) . . . 15

Bagian 1

1. Ringkasan Sistem (System Overview)

3	13	2	6
peran pengguna (RBAC)	tabel entitas surat	use case kunci	temuan audit teknis

1.1 Deskripsi singkat dan latar belakang

Aplikasi **E-Arsip PTKP** adalah sistem informasi manajemen persuratan dan pengarsipan elektronik berbasis web yang dirancang untuk mengotomatisasi siklus hidup dokumen internal dan eksternal.

Sistem ini dikembangkan untuk mengatasi kendala konvensional dalam administrasi perusahaan:

- **Penomoran surat duplikat atau loncat.** Penomoran manual kerap menimbulkan tumpang tindih antar bagian atau divisi.
- **Redundansi dan kehilangan dokumen fisik.** Dokumen cetak rentan hilang, rusak, serta lambat untuk didisposisikan antar unit kerja.
- **Sentralisasi repositori dokumen.** Dibutuhkan penyimpanan terpusat yang aman, terindeks, dan dapat diakses cepat berdasarkan tahun, klasifikasi atau lemari arsip, dan unit kerja penerbit.

1.2 Tujuan utama pengembangan

1. **Otomatisasi penomoran surat (letter numbering engine).** Menghasilkan nomor urut dan kode registrasi surat secara dinamis sesuai format tata naskah dinas.
2. **Digitalisasi manajemen naskah dan dokumen.** Pengelolaan dokumen keluar eksternal, surat tugas, surat keputusan, nota dinas, memo internal, surat kontrak atau SPK, berita acara, surat kuasa, dan pengumuman.
3. **Distribusi dokumen lintas departemen.** Memfasilitasi korespondensi internal dua arah (nota dinas keluar dan nota dinas masuk) antar unit kerja.
4. **Pencarian dan pelacakan arsip cepat (searchability).** Integrasi server-side DataTables untuk penyaringan berkas berdasarkan unit kerja, tanggal, perihal, dan berkas lampiran digital (PDF, JPG, DOCX).

Format nomor surat

[No Urut] / [Kode Dokumen] / [Kode Perusahaan (PTKP)] / [Bulan Romawi] / [Tahun]

Contoh: 01/ST/PTKP/X/2026

1.3 Target pengguna dan batasan ruang lingkup

Target pengguna

Super Administrator (IT / Sistem)

Mengelola konfigurasi sistem, akun pengguna, master departemen, master unit kerja, master klasifikasi arsip, dan hak akses relasi.

Operator departemen / unit kerja

Pegawai atau sekretariat divisi (grup `trainer`) yang menerbitkan nomor surat, meregistrasi dokumen keluar, mendistribusikan nota dinas dan memo, serta mengunggah berkas arsip.

Pegawai umum / penerima

Pengguna tingkat dasar (grup `peserta`) untuk memantau pengumuman dan menelusuri dokumen publik unit kerjanya.

Batasan ruang lingkup (scope boundaries)

In-scope	Out-of-scope
• Registrasi dan auto-numbering surat keluar eksternal dan berbagai jenis surat resmi (SK, ST, SKET, SPK, BA, Kuasa, Pengantar, Pernyataan). • Distribusi korespondensi internal dua arah (Nota Dinas Masuk/Keluar, Memo Masuk/Keluar). • Manajemen berkas digital (unggah lampiran PDF, DOCX, gambar). • Manajemen data master keorganisasian (Departemen, Unit Kerja, Lemari/Klasifikasi Arsip).	• Integrasi digital signature berbasis sertifikat digital X.509 (BSrE / Peruri CA). Saat ini masih mengandalkan unggahan pindaian fisik (scan). • Pelacakan disposisi berjenjang (hierarchical approval workflow / multiapproval tracking). • Mesin OCR (Optical Character Recognition) untuk pengindeksan isi konten di dalam berkas dokumen.

Bagian 2

2. Hak Akses dan Manajemen Peran (RBAC)

Sistem menggunakan pustaka otentikasi **Ion Auth** yang mengintegrasikan pengguna (`users`) ke dalam grup otorisasi (`groups`).

2.1 Identifikasi peran (roles)

Role ID	Nama role sistem	Label fungsional bisnis	Deskripsi tanggung jawab
1	`admin`	**System Administrator**	Kendali penuh konfigurasi teknis, user management, audit data master, dan pemantauan seluruh repositori arsip.
2	`trainer`	**Operator Unit / Konseptor Arsip**	Representasi fungsional sekretariat divisi atau unit kerja. Berwenang men-generate nomor surat, menginput dokumen, dan mendistribusikan nota dinas dan memo.
3	`peserta`	**Staff / Viewer**	Pengguna read-only dengan hak akses terbatas: melihat daftar arsip dan pengumuman umum.

Catatan analis
Nama peran `trainer` dan `peserta` merupakan artefak warisan (legacy code) dari fondasi aplikasi awal, yaitu sistem ujian atau pelatihan online, yang telah diadaptasi fungsinya menjadi sistem E-Arsip.

2.2 Matriks hak akses (CRUD matrix)

C Create (tambah data / generate nomor) **R** Read (lihat, unduh, detail) **U** Update (ubah, edit)
D Delete (hapus, hapus massal) **O** Own-only (hanya milik unit / pembuat) **-** Tidak ada akses (HTTP 403)

Modul / fitur sistem	admin	trainer	peserta
Autentikasi dan profil			
Login / Logout / Reset sandi	CRU	CRU	CRU
Update foto profil dan akun pribadi	CRU	U (O)	U (O)
Dokumen eksternal dan surat resmi			
Surat Keluar Eksternal (`Materi`)	CRUD	CRUD (O)	R
Surat Tugas (`Surattugas`)	CRUD	CRUD (O)	R
Surat Keputusan (`Keputusan`)	CRUD	CRUD (O)	R
Surat Berita Acara (`Suratba`)	CRUD	CRUD (O)	R

Modul / fitur sistem	admin	trainer	peserta
Surat Kontrak / SPK (`Suratkontrak`)	CRUD	CRUD (O)	R
Surat Kuasa (`Suratkuasa`)	CRUD	CRUD (O)	R
Surat Pengantar (`Suratpengantar`)	CRUD	CRUD (O)	R
Surat Keterangan (`Suratketerangan`)	CRUD	CRUD (O)	R
Surat Pernyataan (`Suratpernyataan`)	CRUD	CRUD (O)	R
Korespondensi internal			
Nota Dinas Keluar (`Knotadinas`)	CRUD	CRUD (O)	-
Nota Dinas Masuk (`Mnotadinas`)	CRUD	R (jika sebagai penerima)	-
Memo Keluar (`Kmemo`)	CRUD	CRUD (O)	-
Memo Masuk (`Mmemo`)	CRUD	R (jika sebagai penerima)	-
Buat Pengumuman (`Pengumuman`)	CRUD	CRUD	R
Data master dan konfigurasi			
Master Departemen	CRUD	-	-
Master Unit Kerja	CRUD	-	-
Master Arsip / Lemari (`Pelatihan`)	CRUD	-	-
Master Pengguna / Pegawai (`Trainer`)	CRUD	-	-
Relasi Pengguna ↔ Departemen	CRUD	-	-
Relasi Arsip ↔ Departemen	CRUD	-	-
User Management (`Users`)	CRUD	-	-
Pengaturan Sistem (`Settings`)	CRUD	-	-

Bagian 3

3. Alur Kerja dan Perilaku Sistem (System Workflow & Behavior)

3.1 Analisis use case

Aktor utama

- **Operator Unit Kerja** (`trainer`): aktor operasional pencatat dan pembuat naskah dinas.
- **Penerima Unit Kerja** (`trainer` penerima): penerima nota dinas atau memo antar departemen.
- **Administrator** (`admin`): aktor pengatur tata kelola data master dan keamanan akun.

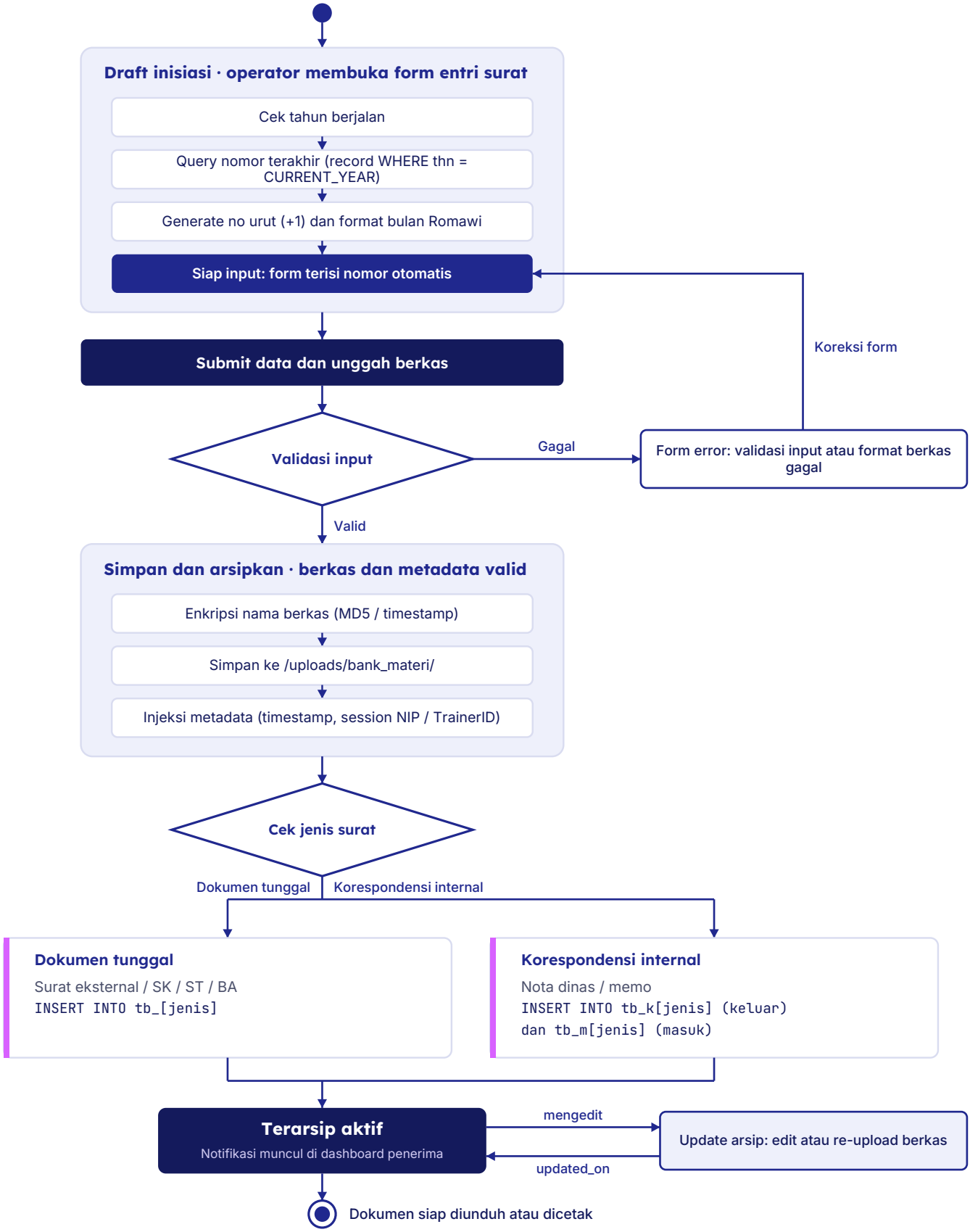
Skenario use case kunci

UC-01	Penerbitan dan pengarsipan surat keluar / dokumen eksternal
Pemicu	Operator divisi perlu membuat surat resmi keluar perusahaan ke instansi eksternal.
Skenario utama	1. Operator membuka menu **Dokumen Eksternal > Tambah Surat**. 2. Sistem mengeksekusi `generateNomorUrut()`, mencari urutan nomor terbesar di tahun berjalan, dan mengembalikan nomor berformat `[Urut]/[KodeDivisi]/PTKP/[BulanRomawi]/[Tahun]`. 3. Operator mengisi form metadata: perihal, pengirim, tujuan kepada, tanggal surat, serta mengunggah pindaian berkas fisik (PDF/DOCX). 4. Sistem memvalidasi input, memindahkan berkas ke folder `/uploads/bank_materi/`, mencatat stempel waktu (`created_on`), dan menyimpan record ke database. 5. Dokumen masuk ke dalam repositori arsip digital.
Skenario alternatif	Berkas tidak valid atau format tidak didukung: sistem melempar pesan File Upload Error dan membatalkan transaksi.

UC-02	Distribusi korespondensi nota dinas antar departemen
Pemicu	Divisi A ingin mengirim instruksi resmi internal ke Divisi B dan Divisi C.
Skenario utama	1. Operator Divisi A membuka **Nota Dinas Keluar > Tambah Data**. 2. Sistem memberikan nomor agenda keluar baru. 3. Operator memilih satu atau banyak unit tujuan (`sent_trainer_id`), mengisi perihal, isi ringkasan, dan lampiran. 4. Saat disimpan (`Knotadinas::save()`), sistem mengeksekusi dua operasi penyimpanan: (a) menyimpan entri ke `tb_knotadinas` sebagai arsip keluar pengirim, dan (b) menyimpan duplikasi entri ke `tb_mnotadinas` sebagai arsip masuk penerima dengan relasi `sent_trainer_id`. 5. Operator penerima di Divisi B dan C melihat nota dinas tersebut pada daftar **Nota Dinas Masuk**.

3.2 State flow: siklus registrasi dokumen dan korespondensi

Alur dari pembukaan form entri hingga dokumen terarsip dan siap diunduh atau dicetak, termasuk percabangan dokumen tunggal dan korespondensi internal.



Bagian 4

4. Arsitektur dan Struktur Database

Aplikasi menggunakan basis data relasional MariaDB/MySQL dengan naming convention campuran antara entitas core (hasil adaptasi legacy) dan entitas domain arsip berkode awalan `tb_`.

4.1 Diagram entitas relasi (ERD)

Keterangan: `1` = sisi satu, `N` = sisi banyak. Setiap tabel dokumen juga memuat `pelatihan_id` (FK ke `pelatihan`) sebagai klasifikasi arsip.



Relasi pegawai ke tabel dokumen lain



Skema seragam: `tb_kmemo` `tb_mmemo` `tb_suratkuasa` `tb_suratketerangan` `tb_suratpengantar` `tb_suratpernyataan`

4.2 Struktur tabel utama dan konstrain kunci

Tabel tata kelola pengguna dan keamanan

Tabel	Kolom kunci	Keterangan
`users`	`id` (INT UNSIGNED, PK, auto increment) `username1` (VARCHAR 254) `password` (VARCHAR 255) `nip` (VARCHAR 100, NULL) `level` (VARCHAR 100)	Tabel akun autentikasi utama. `username1` adalah nama pengguna untuk login. `password` menyimpan hash kata sandi (Bcrypt via Ion Auth). `nip` adalah Nomor Induk Pegawai penghubung dengan identitas unit kerja. `level` menyatakan status hak akses.
`groups` dan `users_groups`	Relasi M:N	Tabel relasi Role-Based Access Control (RBAC).

Tabel struktur organisasi dan pengelompokan

Tabel	Kolom	Fungsi
`departemen`	`id_departemen` (INT, PK, auto increment) `nama_departemen` (VARCHAR 30)	Data induk departemen (Pemasaran, SDM, Litbang, Keuangan, dan sebagainya).
`unitkerja`	`id_unitkerja` (INT, PK, auto increment) `nama_unitkerja` (VARCHAR 30) `departemen_id` (INT, FK ke `departemen`)	Data seksi atau unit kerja bawahan departemen.
`pelatihan`	`id_pelatihan` (INT, PK, auto increment) `nama_pelatihan` (VARCHAR 50)	Fungsional: lemari atau klasifikasi dokumen.
`trainer`	`id_trainer` (INT, PK, auto increment) `nip` (CHAR 12, unique/key) `nama` (VARCHAR 50) `unitkerja_id` (INT) `pelatihan_id` (INT)	Fungsional: pegawai atau operator surat.

Tabel dokumen dan arsip surat

Semua tabel entitas surat memiliki skema seragam: `tb_materi`, `tb_knotadinas`, `tb_mnotadinas`, `tb_kmemo`, `tb_mmemo`, `tb_surattugas`, `tb_keputusan`, `tb_suratba`, `tb_suratkontrak`, `tb_suratkuasa`, `tb_suratketerangan`, `tb_suratpengantar`, dan `tb_suratpernyataan`.

Nama kolom	Tipe data	Kategori	Fungsi dan keterangan
`id_[jenis]`	`INT(11)`	**PK**	Kunci utama transaksi dokumen (auto increment).
`trainer_id`	`INT(11)`	**FK**	ID pegawai atau konseptor surat (terhubung ke `trainer.id_trainer`).
`pelatihan_id`	`INT(11)`	**FK**	Kategori klasifikasi arsip (terhubung ke `pelatihan.id_pelatihan`).
`nomor_urut`	`VARCHAR(150)`	Data kunci	Nomor urut surat (misal `01`, `02`).
`nomor_surat`	`VARCHAR(100)`	Data kunci	Nomor lengkap resmi (misal `01/ST/PTKP/X/2026`). Di-index secara logis untuk `LIKE '%/YYYY'`.
`pengirim`	`VARCHAR(100)`	Atribut	Nama atau unit kerja penerbit surat.
`kepada`	`VARCHAR(100)`	Atribut	Pihak penerima dokumen (khusus dokumen eksternal).
`sent_trainer_id`	`VARCHAR(111)`	Atribut	ID unit penerima (pada nota dinas atau memo; format comma-separated).
`tanggal_surat`	`DATE`	Waktu	Tanggal resmi naskah dikeluarkan.
`ringkasan` / `materi`	`LONGTEXT`	Konten	Perihal surat atau deskripsi isi dokumen.
`file`	`VARCHAR(255)`	Berkas	Nama berkas lampiran yang tersimpan di filesystem.
`created_on`	`INT(11)`	Audit	Unix timestamp saat data pertama kali dibuat.
`updated_on`	`INT(11)`	Audit	Unix timestamp saat terjadi modifikasi terakhir.

Bagian 5

5. Catatan Teknis dan Rekomendasi Arsitektural (Technical Audit)

Berdasarkan audit statis terhadap kode sumber dan skema basis data, terdapat temuan teknis berprioritas tinggi yang memerlukan tindakan mitigasi.

5.1 Redundansi data dan skema warisan (legacy schema debt)

5.1.1 Atribut sampah dari sistem ujian online

Skema warisan

Temuan	Pada hampir seluruh tabel arsip (`tb_materi`, `tb_keputusan`, `tb_kmemo`, `tb_surattugas`) ditemukan kolom `opsi_a`, `opsi_b`, `opsi_c`, `opsi_d`, `opsi_e`, `file_a..e`, `jawaban`, dan `bobot`.
Dampak	Pemborosan alokasi penyimpanan baris (storage overhead), pembengkakan ukuran tabel, serta merusak kejelasan semantik kode bagi pengembang berikutnya.
Rekomendasi	Jalankan skrip migrasi `ALTER TABLE DROP COLUMN` untuk mengeliminasi seluruh kolom residu yang tidak digunakan lagi.

5.1.2 Duplikasi data sinkronisasi (dual-insert antipattern)

Integritas data

Temuan	Pada pengiriman Nota Dinas (`Knotadinas::save()`), sistem mengeksekusi dua `INSERT` terpisah ke `tb_knotadinas` dan `tb_mnotadinas` dengan payload berkas fisik yang sama.
Dampak	Ketidaksinkronan data (data anomaly) apabila record keluar diedit namun record masuk tidak terupdate atau hilang integritasnya.
Rekomendasi	Normalisasi menjadi satu tabel induk `surat_internal` dengan tabel anak `surat_internal_recipients` (M:N) yang mencatat status baca per penerima.

5.2 Pelanggaran normalisasi (1NF violation)

5.2.1 Kolom sent_trainer_id berisi data comma-separated

Normalisasi

Temuan	Kolom `sent_trainer_id` diisi data comma-separated (contoh: `"8,9,10"`), dan pencarian data unread menggunakan `FIND_IN_SET()`.
Dampak	Menghambat penggunaan B-Tree indexing pada basis data, memaksa MySQL melakukan full table scan pada jutaan baris dokumen, yang akan memicu lonjakan CPU (high latency query).
Rekomendasi	Pisahkan ke dalam tabel pivot relasional berindeks (lihat contoh di bawah).

```
CREATE TABLE `tb_surat_penerima` (
  `id` INT AUTO_INCREMENT PRIMARY KEY,
  `surat_id` INT NOT NULL,
  `jenis_surat` ENUM('notadinas', 'memo') NOT NULL,
  `trainer_id` INT NOT NULL,
  `status_baca` TINYINT(1) DEFAULT 0,
  INDEX (`trainer_id`, `status_baca`)
);
```

5.3 Celah keamanan (security gaps)

5.3.1 Potensi kerentanan eksekusi berkas arbitrer (file upload)

Keamanan

Temuan	Pada `file_config()` di controller terdapat mime-types seperti `application/octet-stream` yang diizinkan, dan penyimpanan dilakukan pada direktori publik `/uploads/bank_materi/`.
Dampak	Risiko pengunggahan web shell (misal berkas berbahaya berekstensi ganda atau manipulasi header `.php`) yang dapat dieksekusi langsung melalui browser jika konfigurasi `.htaccess` tidak mengunci eksekusi PHP pada direktori unggahan.
Rekomendasi	• Nonaktifkan eksekusi skrip PHP di folder `/uploads` melalui `.htaccess` (`php_flag engine off` / `SetHandler default-handler`). • Simpan file di luar direktori `public_html` / `document_root` dan sajikan file hanya melalui download controller streaming berotentikasi.

5.3.2 Ketiadaan otorisasi berbasis kepemilikan (IDOR)

Keamanan

Temuan	Pada operasi `edit($id)` dan `delete()`, sistem hanya mengecek apakah pengguna bertipe `trainer` atau `admin`, tanpa memvalidasi apakah `$id` dokumen tersebut benar-benar diterbitkan oleh `trainer_id` yang sedang login.
Dampak	Pengguna dari satu divisi dapat memodifikasi atau menghapus nomor surat milik divisi lain hanya dengan mengubah parameter ID pada request HTTP POST.
Rekomendasi	Tambahkan klausa verifikasi kepemilikan data (lihat contoh di bawah).

```
if (!$this->ion_auth->is_admin()) {
    $dokumen = $this->materi->getMateriById($id);
    if ($dokumen->trainer_id !== $current_user->id_trainer) {
        show_error('Anda tidak berhak memodifikasi dokumen divisi lain.', 403);
    }
}
```

5.4 Race condition pada generator nomor surat

5.4.1 Nomor surat ganda saat penginputan serentak

Konkurensi

Temuan	Logika `generateNomorUrut()` mengambil nomor terakhir dengan `SELECT ... ORDER BY id DESC LIMIT 1`, kemudian ditambah satu (`+1`) di layer PHP sebelum di-insert.
Dampak	Jika dua operator dari unit berbeda menekan submit secara bersamaan di detik yang sama (concurrency), keduanya akan mendapatkan nomor surat yang identik (duplicate letter number).
Rekomendasi	Gunakan transaksi dengan row-level locking (`SELECT ... FOR UPDATE`) atau tabel sekuens counter khusus per tahun (lihat contoh di bawah).

```
-- Atomic counter table
INSERT INTO surat_sequences (tahun, kode_dokumen, last_number)
VALUES (2026, 'ST', 1)
ON DUPLICATE KEY UPDATE last_number = LAST_INSERT_ID(last_number + 1);
```

Bagian 6

6. Ringkasan Evaluasi Arsitektur (Executive Summary)

Tabel berikut merangkum status arsitektur saat ini, dampaknya terhadap bisnis dan operasional, serta rekomendasi prioritas.

Parameter arsitektural	Status saat ini	Dampak bisnis / operasional	Rekomendasi prioritas
Kematangan pola (MVC)	Cukup (CodeIgniter 3)	Sederhana, mudah dipahami tim lokal.	Pertimbangkan migrasi bertahap ke CI 4 atau Laravel (PHP 8.2+).
Pemisahan peran (RBAC)	Fungsional	Terimplementasi via Ion Auth, namun hak akses granular per unit belum ketat.	Terapkan validasi kepemilikan data (IDOR hardening).
Performa skema DB	Butuh optimasi	Banyak kolom tidak terpakai (legacy exam tables) dan `FIND_IN_SET`.	Normalisasi tabel penerima naskah dan eliminasi kolom residu.
Integritas penomoran	Rentan tabrakan	Potensi nomor ganda jika penginputan dilakukan serentak (concurrent).	Ganti mekanisme generator ke atomic lock / sequence transaction.